

Marco Integrativo GQM + PRAGMATIC

Trazabilidad desde Objetivos Nacionales hasta Datos Técnicos de Ciberseguridad

Kit GQM-PRAGMATIC v2025.1 • Aplicación al Marco COSO • España / UE

"Una métrica sin objetivo es un número sin significado. Un objetivo sin métrica es una declaración de intenciones. GQM es el puente; PRAGMATIC es el filtro de calidad. Juntos, convierten el instinto en evidencia."

1. Fundamento del Marco Integrativo

1.1 La Metodología GQM (Goal-Question-Metric)

La metodología **GQM** fue formulada por Victor R. Basili (University of Maryland / Fraunhofer IESE, 1994). Es el estándar de referencia para la definición de métricas de seguridad de la información, incorporado en la **ISO/IEC 15939:2007** y en la **ISO/IEC 27004:2016**.

El modelo opera en tres niveles encadenados:

NIVEL CONCEPTUAL	→ OBJETIVO (Goal)	— QUÉ, PARA QUIÉN, CON QUÉ PROPÓSITO
	↓	
NIVEL OPERACIONAL	→ PREGUNTA (Question)	— QUÉ SE NECESITA SABER
	↓	
NIVEL CUANTITATIVO	→ MÉTRICA (Metric)	— QUÉ DATO RESPONDE LA PREGUNTA

Plantilla canónica del Goal:

Analizar [objeto] con el propósito de [propósito] respecto a [atributo de calidad] desde el punto de vista de [agente] en el contexto de [entorno organizacional]

1.2 El Modelo PRAGMATIC (Brotby & Hinson, 2013)

El modelo **PRAGMATIC** evalúa la calidad de una métrica bajo 9 criterios, adoptado por ISACA (CISM, CRISC) y referenciado en **NIST SP 800-55 Rev. 2 (2022)**:

Criterio	Denominación	Pregunta clave de evaluación
P	Predictivo	¿Permite anticipar un problema antes de que ocurra?
R	Relevante	¿Está alineada con objetivos reales del negocio y del Consejo?
A	Accionable	¿Puede generar una decisión o acción concreta si cambia?
G	Genuino	¿Mide lo que dice medir, sin artefactos ni manipulaciones?
M	Meaningful (Significativo)	¿Tiene contexto para ser interpretable por el Consejo?
A	Accurate (Preciso)	¿Los datos son exactos con margen de error conocido?
T	Timely (Oportuno)	¿Está disponible cuando se necesita para decidir?
I	Independiente	¿Está libre de conflicto de interés en su generación?
C	Cost-effective (Rentable)	¿El coste de medición es proporcional al valor de la información?

Escala de calificación: 1 (muy bajo) — 5 (muy alto) por criterio · Umbral mínimo de calidad: ≥ 3

Puntuación Total PRAGMATIC (máximo 45 puntos):

Rango	Clasificación	Acción
36-45	Premium 	Implementación prioritaria y recomendada
27-35	Aceptable 	Implementar con mejoras menores en criterios débiles
18-26	Condicional 	Revisar criterios < 3 antes de implementar
< 18	Baja calidad 	Descartar o rediseñar completamente

1.3 La Integración GQM + PRAGMATIC en el Marco COSO

La integración responde a tres necesidades simultáneas:

1. Trazabilidad vertical: Conectar los Objetivos Nacionales (ENS, NIS2, Estrategia Ciber España 2025-2030) con las métricas técnicas que las organizaciones producen cotidianamente.
2. Filtro de calidad: PRAGMATIC elimina las métricas vanidad — las que existen porque son fáciles de medir, no porque aporten valor decisional.
3. Lenguaje ejecutivo: El GQM estructura el razonamiento; PRAGMATIC justifica cada métrica ante el CFO y el Consejo en términos de relevancia, coste y oportunidad.

2. Arquitectura del Marco: De lo Nacional a lo Técnico

2.1 Nivel 0 — Objetivos Nacionales y Regulatorios

Código	Objetivo Nacional / Regulatorio	Fuente Primaria
ON-1	Mejorar la resiliencia de infraestructuras críticas frente a ciberataques	ENS RD 311/2022 · Estrategia Ciber España 2025–30, Eje 1
ON-2	Garantizar la continuidad de servicios esenciales ante incidentes digitales	NIS2 Art. 21(1) · DORA Arts. 11–12
ON-3	Fortalecer el gobierno corporativo del ciberriesgo en los consejos	COSO CGF 2026 P-8 · NIS2 Art. 20
ON-4	Cuantificar y comunicar el ciberriesgo en términos financieros	COSO ERM 2017 P-9 · NIST IR 8286r1 · FAIR
ON-5	Reducir el tiempo de detección y respuesta ante incidentes	NIS2 Art. 23 · DORA Art. 19 · CCN-CERT 2025
ON-6	Gestionar el riesgo de la cadena de suministro digital	NIS2 Art. 21(2d) · DORA Art. 28–30
ON-7	Preparar el ecosistema tecnológico ante la amenaza cuántica	NIST PQC 2024–25 · CCN-CERT Quantum 2025
ON-8	Garantizar supervisión independiente y rendición de cuentas del ciberriesgo	COSO IC 2013 · NIS2 Art. 20(2)

2.2 Nivel 1 — Objetivos Organizacionales COSO

Código	Objetivo Organizacional	ON Origen	Componente COSO
OO-1	El Consejo supervisa activamente el ciberriesgo con competencia y regularidad	ON-3	C-I Gobernanza
OO-2	El ciberriesgo está cuantificado financieramente e integrado en la estrategia	ON-4	C-II Estrategia
OO-3	Los controles de detección reducen el tiempo de exposición ante incidentes	ON-5	C-III Desempeño
OO-4	Las vulnerabilidades críticas se parchean dentro de ventanas de exposición mínimas	ON-1, ON-5	C-III Desempeño
OO-5	Las identidades privilegiadas están controladas y auditadas en tiempo real	ON-1	C-III Desempeño
OO-6	La cadena de suministro no amplifica el riesgo de la organización	ON-6	C-III Desempeño
OO-7	La resiliencia organizacional garantiza la continuidad ante incidentes mayores	ON-2	C-III Desempeño
OO-8	Los riesgos emergentes (IA adversarial, PQC) están identificados y en hoja de ruta	ON-7	C-II + C-III
OO-9	El reporte de ciberriesgo al Consejo es comprensible, oportuno y accionable	ON-3, ON-4	C-V Reporte
OO-10	La inversión en ciberseguridad genera retorno demostrable (ROSI positivo)	ON-4	C-II + FAIR

3. Despliegue QQM Completo por Objetivo Organizacional

OO-1: Gobierno y Supervisión del Ciberriesgo por el Consejo

Goal QQM-1:

Analizar la frecuencia y calidad de la supervisión del ciberriesgo por el Consejo de Administración, con el propósito de mejorar la gobernanza corporativa del ciberriesgo, respecto al principio de oversight efectivo, desde el punto de vista del regulador y del accionista, en el contexto de organizaciones sujetas a NIS2 y COSO CGF 2026.

Pregunta QQM	Métrica Derivada	Cód. Métrica	Tipo	Fuente de Datos
Q1.1: ¿Con qué frecuencia el Consejo revisa el ciberriesgo?	Frecuencia de revisión del ciberriesgo en el Consejo (sesiones/año)	M-GOB-01	Cuantitativa discreta	Actas del Consejo
Q1.2: ¿Qué porcentaje de consejeros tiene formación en ciberseguridad?	% de consejeros con competencia ciber acreditada	M-GOB-02	Cuantitativa continua	RRHH / curriculum vitae
Q1.3: ¿Existe un comité especializado con mandato ciber formal?	Existencia y nivel de actividad del Comité Ciber del Consejo (0-3)	M-GOB-03	Ordinal	Estatutos / actas
Q1.4: ¿El CISO tiene acceso directo y estructurado al Consejo?	Nivel de independencia del reporte del CISO (escala 1-5)	M-GOB-04	Ordinal	Organigrama / política
Q1.5: ¿Se ha formalizado el apetito de ciberriesgo?	Apetito de ciberriesgo cuantificado en euros (sí/no + valor €)	M-GOB-05	Nominal + cuantitativa	Declaración de apetito

OO-2: Cuantificación Financiera del Ciberriesgo e Integración Estratégica

Goal QQM-2:

Analizar el grado de integración del ciberriesgo en la planificación estratégica y su cuantificación financiera, con el propósito de mejorar la calidad de las decisiones de inversión en ciberseguridad,

respecto al atributo de toma de decisiones basada en evidencia, desde el punto de vista del CFO y del Consejo, en el contexto COSO ERM + metodología FAIR.

Pregunta QGM	Métrica Derivada	Cód. Métrica	Tipo	Fuente de Datos
Q2.1: ¿El ciberriesgo informa decisiones estratégicas clave?	Nivel de integración ciber en el plan estratégico (escala 1-5)	M-EST-01	Ordinal	Plan estratégico / entrevistas
Q2.2: ¿Se cuantifica el ciberriesgo en términos financieros?	Metodología de cuantificación utilizada (FAIR, ALE, Monte Carlo, cualitativa, ninguna)	M-EST-02	Nominal	Documentación GRC
Q2.3: ¿Cuál es el ALE total del portafolio de ciberriesgos?	ALE (Annual Loss Expectancy) total en euros	M-EST-03	Cuantitativa continua	Plataforma CRQ / hojas FAIR
Q2.4: ¿Se actualiza la cuantificación ante cambios del entorno?	Frecuencia de actualización de la cuantificación del riesgo (veces/año)	M-EST-04	Cuantitativa discreta	Registros GRC
Q2.5: ¿Existe cobertura de seguro de ciberriesgo proporcional al ALE?	Ratio cobertura de seguro / ALE estimado	M-EST-05	Cuantitativa ratio	Póliza + modelo ALE

OO-3: Detección y Respuesta — MTTD y MTTR

Goal GQM-3:

Analizar la capacidad de detección y respuesta ante incidentes de ciberseguridad, con el propósito de reducir el tiempo de exposición del adversario en el entorno, respecto al atributo de eficiencia operativa del SOC, desde el punto de vista del CISO y del regulador NIS2/DORA, en el contexto de operaciones 24/7 con presencia en España.

Pregunta GQM	Métrica Derivada	Cód. Métrica	Tipo	Fuente de Datos
Q3.1: ¿Cuánto tarda la organización en detectar un incidente activo?	MTTD — Mean Time to Detect (horas)	M-DET-01	Cuantitativa continua	SIEM / registros de incidentes
Q3.2: ¿Cuánto tarda en contener el incidente tras su detección?	MTTR — Mean Time to Respond (horas)	M-DET-02	Cuantitativa continua	Plataforma IR / tickets
Q3.3: ¿El MTTD está mejorando a lo largo del tiempo?	Tendencia trimestral del MTTD (delta %)	M-DET-03	Cuantitativa ratio	SIEM histórico
Q3.4: ¿Qué porcentaje de incidentes son detectados internamente?	% de incidentes detectados por controles propios vs. notificación externa	M-DET-04	Cuantitativa porcentaje	Registros IR
Q3.5: ¿Cuál es el tiempo de exposición medio del adversario (dwell time)?	Dwell Time medio (días entre compromiso inicial y detección)	M-DET-05	Cuantitativa continua	SIEM + forense post-incidente

OO-4: Gestión de Vulnerabilidades y Time-to-Patch

Goal GQM-4:

Analizar la efectividad del proceso de gestión de vulnerabilidades, con el propósito de minimizar la ventana de explotación disponible para el adversario, respecto al atributo de reducción de superficie de ataque, desde el punto de vista del CISO y del equipo de operaciones de seguridad, en el contexto de infraestructuras heterogéneas IT/OT/Cloud.

Pregunta GQM	Métrica Derivada	Cód. Métrica	Tipo	Fuente de Datos
Q4.1: ¿Cuánto se tarda en parchear vulnerabilidades críticas (CVSS $\geq$ 9.0)?	Time-to-Patch crítico: mediana de días hasta remediación de CVSS $\geq$ 9.0	M-VUL-01	Cuantitativa continua	Scanner de vulnerabilidades
Q4.2: ¿Qué porcentaje de vulnerabilidades críticas siguen abiertas >30 días?	% CVE críticos sin parchear en >30 días sobre el total activo	M-VUL-02	Cuantitativa porcentaje	Scanner + CMDB
Q4.3: ¿Se prioriza con EPSS además de CVSS?	% de vulnerabilidades priorizadas con EPSS (Exploit Prediction Score)	M-VUL-03	Cuantitativa porcentaje	Plataforma VM con EPSS feed
Q4.4: ¿Se gestionan vulnerabilidades en OT/IoT específicamente?	Cobertura del proceso de gestión de vulnerabilidades en activos OT/IoT (%)	M-VUL-04	Cuantitativa porcentaje	Inventario OT + scanner OT
Q4.5: ¿Se gestiona el SBOM de aplicaciones críticas?	% de aplicaciones críticas con SBOM generado y actualizado (<90 días)	M-VUL-05	Cuantitativa porcentaje	Pipeline DevSecOps / SBOM tool

OO-5: Gestión de Identidad, Acceso Privilegiado y MFA

Goal GQM-5:

Analizar el control sobre las identidades privilegiadas y la cobertura de autenticación multifactor, con el propósito de reducir la superficie de ataque relacionada con credenciales comprometidas, respecto al atributo de control de acceso mínimo privilegio, desde el punto de vista del CISO y del equipo IAM, en el contexto de entornos híbridos cloud/on-premise.

Pregunta GQM	Métrica Derivada	Cód. Métrica	Tipo	Fuente de Datos
Q5.1: ¿Qué cobertura tiene el MFA en cuentas privilegiadas?	% de cuentas privilegiadas (admin, root, service) con MFA activo	M-IAM-01	Cuantitativa porcentaje	IAM/PAM platform
Q5.2: ¿Qué cobertura tiene el MFA en acceso remoto y cloud?	% de accesos remotos y aplicaciones cloud críticas con MFA	M-IAM-02	Cuantitativa porcentaje	SSO / VPN logs
Q5.3: ¿Se revisan periódicamente las cuentas privilegiadas?	Días desde la última revisión de cuentas privilegiadas	M-IAM-03	Cuantitativa continua	IAM / PAM audit logs
Q5.4: ¿Se eliminan automáticamente las cuentas de empleados que causan baja?	Tiempo medio de desprovisioning en bajas (horas)	M-IAM-04	Cuantitativa continua	HRMS + IAM integración
Q5.5: ¿Se gestionan las identidades no humanas (API, IoT, service accounts)?	% de identidades no humanas inventariadas y gobernadas (vs. total)	M-IAM-05	Cuantitativa porcentaje	IAM + inventario APIs

OO-6: Riesgo de Terceros y Cadena de Suministro

Goal GQM-6:

Analizar la efectividad del programa de gestión del riesgo de terceros y la cadena de suministro digital, con el propósito de reducir la probabilidad de compromiso a través de proveedores, respecto al atributo de control de la superficie de ataque de terceros, desde el punto de vista del CISO y del Director de Compras, en el contexto de dependencias digitales críticas con proveedores.

Pregunta GQM	Métrica Derivada	Cód. Métrica	Tipo	Fuente de Datos
Q6.1: ¿Qué porcentaje de proveedores críticos tiene evaluación de seguridad vigente?	% de proveedores Tier-1 con evaluación de seguridad < 12 meses	M-SCM-01	Cuantitativa porcentaje	TPRM platform
Q6.2: ¿Se monitoriza continuamente el riesgo de los proveedores críticos?	% de proveedores Tier-1 con monitorización continua de rating de seguridad	M-SCM-02	Cuantitativa porcentaje	Bitsight / SecurityScorecard
Q6.3: ¿Tienen cláusulas contractuales de ciberseguridad los contratos críticos?	% de contratos con proveedores críticos con cláusulas de seguridad y derecho de auditoría	M-SCM-03	Cuantitativa porcentaje	Gestión de contratos
Q6.4: ¿Se tienen planes de continuidad ante el fallo de un proveedor crítico?	% de servicios críticos con plan de continuidad ante fallo del proveedor principal	M-SCM-04	Cuantitativa porcentaje	BCP + mapa de dependencias
Q6.5: ¿Se gestiona el SBOM para controlar la superficie de ataque de software de terceros?	% de aplicaciones críticas de terceros con SBOM y proceso de monitorización de CVEs	M-SCM-05	Cuantitativa porcentaje	DevSecOps / SBOM tool

OO-7: Resiliencia y Continuidad de Negocio

Goal GQM-7:

Analizar el nivel de resiliencia operacional de la organización frente a incidentes de ciberseguridad mayores, con el propósito de garantizar la continuidad de los servicios esenciales, respecto al atributo de recuperabilidad verificada, desde el punto de vista del COO y del regulador DORA/NIS2, en el contexto de operaciones esenciales con tolerancia cero a la interrupción prolongada.

Pregunta GQM	Métrica Derivada	Cód. Métrica	Tipo	Fuente de Datos
Q7.1: ¿El RTO real en pruebas se aproxima al RTO objetivo?	Ratio RTO real (pruebas) / RTO objetivo (%)	M-RES-01	Cuantitativa ratio	Pruebas DRP + objetivos aprobados
Q7.2: ¿El RPO real en pruebas se aproxima al RPO objetivo?	Ratio RPO real (pruebas) / RPO objetivo (%)	M-RES-02	Cuantitativa ratio	Pruebas DRP + objetivos aprobados
Q7.3: ¿Con qué frecuencia se prueban los planes de continuidad?	Número de pruebas de recuperación real realizadas en los últimos 12 meses	M-RES-03	Cuantitativa discreta	Registros de pruebas DRP
Q7.4: ¿Participan la alta dirección y el Consejo en los ejercicios de simulación?	% de ejercicios tabletop con participación documentada de C-level	M-RES-04	Cuantitativa porcentaje	Registros de ejercicios
Q7.5: ¿Los backups están protegidos contra ransomware?	% de backups críticos en modalidad offline/inmutable verificados en los últimos 30 días	M-RES-05	Cuantitativa porcentaje	Plataforma backup + logs de verificación

OO-8: Riesgos Emergentes — IA Adversarial y Criptografía Post-Cuántica

Goal GQM-8:

Analizar el nivel de preparación organizacional ante los riesgos emergentes de la IA adversarial y la computación cuántica, con el propósito de anticipar y mitigar amenazas de próxima generación antes de su materialización a escala, respecto al atributo de anticipación estratégica del riesgo, desde el punto de vista del CISO y del arquitecto de ciberseguridad, en el contexto de las publicaciones NIST PQC 2024-25 y la automatización adversarial IA en 2025-26.

Pregunta GQM	Métrica Derivada	Cód. Métrica	Tipo	Fuente de Datos
Q8.1: ¿Se ha realizado inventario criptográfico para identificar algoritmos vulnerables?	% de sistemas de producción con inventario criptográfico completado (RSA, ECDSA, DH identificados)	M-EMG-01	Cuantitativa porcentaje	Crypto audit + CMDB
Q8.2: ¿Existe hoja de ruta de migración a PQC aprobada?	Estado de la hoja de ruta PQC (0: inexistente / 1: en elaboración / 2: aprobada / 3: en ejecución)	M-EMG-02	Ordinal	Documentación estratégica
Q8.3: ¿Se monitorizan activamente los ataques automatizados por IA?	% de reglas de detección SOC específicas para patrones de ataque automatizado por IA	M-EMG-03	Cuantitativa porcentaje	SIEM / EDR rule set
Q8.4: ¿Se gestiona el riesgo de los sistemas de IA propios?	% de sistemas IA internos con evaluación de riesgo pre-despliegue completada	M-EMG-04	Cuantitativa porcentaje	AI inventory + risk assessment
Q8.5: ¿Se ha evaluado el riesgo cuántico sobre datos con vida útil larga?	% de datos con vida útil >10 años evaluados por riesgo de "Store Now, Decrypt Later"	M-EMG-05	Cuantitativa porcentaje	Clasificación de datos + crypto audit

OO-9: Calidad del Reporte de Ciberriesgo al Consejo

Goal GQM-9:

Analizar la calidad, frecuencia y comprensibilidad del reporte de ciberriesgo al Consejo de Administración, con el propósito de mejorar la capacidad del Consejo para supervisar y decidir sobre el ciberriesgo, respecto al atributo de comunicación efectiva del riesgo en lenguaje ejecutivo, desde el punto de vista del Consejo y del Comité de Auditoría, en el contexto COSO C-V (Información y Comunicación).

Pregunta GQM	Métrica Derivada	Cód. Métrica	Tipo	Fuente de Datos
Q9.1: ¿Con qué frecuencia llega el reporte ciber al Consejo?	Frecuencia de reporte de ciberriesgo al Consejo (veces/año)	M-RPT-01	Cuantitativa discreta	Actas del Consejo
Q9.2: ¿El reporte incluye métricas financieras comprensibles para el Consejo?	% de indicadores del reporte expresados en términos financieros (vs. total de indicadores)	M-RPT-02	Cuantitativa porcentaje	Plantilla de reporte al Consejo
Q9.3: ¿El reporte compara el estado actual con el apetito de riesgo aprobado?	Presencia y calidad de la comparativa estado / apetito de riesgo en el reporte (0-3)	M-RPT-03	Ordinal	Análisis del reporte
Q9.4: ¿Existe protocolo de escalado ante incidentes significativos probado?	Estado del protocolo de escalado (0: inexistente / 1: documentado / 2: probado / 3: optimizado)	M-RPT-04	Ordinal	Plan de respuesta a incidentes
Q9.5: ¿La información llega en el tiempo adecuado para que el Consejo pueda actuar?	Tiempo medio entre ocurrencia del evento ciber significativo y conocimiento del Consejo (horas)	M-RPT-05	Cuantitativa continua	Logs de escalado / actas de emergencia

OO-10: Retorno sobre la Inversión en Ciberseguridad (ROSI)

Goal GQM-10:

Analizar el retorno de la inversión en el programa de ciberseguridad, con el propósito de optimizar la asignación de recursos y demostrar el valor financiero de los controles de seguridad, respecto al atributo de eficiencia de la inversión en control, desde el punto de vista del CFO y del Consejo, en el contexto de la metodología FAIR y ROSI como herramienta de comunicación ejecutiva.

Pregunta GQM	Métrica Derivada	Cód. Métrica	Tipo	Fuente de Datos
Q10.1: ¿Cuál es el ROSI del programa de ciberseguridad?	$ROSI = (ALE_{sin} - ALE_{con} - Coste_{control}) / Coste_{control} \times 100 (\%)$	M-ROI-01	Cuantitativa continua	Modelo FAIR / hojas ALE
Q10.2: ¿Cuál es el coste de la inversión como % de ingresos?	$Gasto\ en\ ciberseguridad / ingresos\ totales \times 100 (\%)$	M-ROI-02	Cuantitativa ratio	Presupuesto + P&L
Q10.3: ¿Cuál es la reducción del riesgo conseguida por el programa?	Delta ALE: $ALE_{sin\ program} - ALE_{con\ program}$ (euros/año)	M-ROI-03	Cuantitativa continua	Modelo ALE/FAIR
Q10.4: ¿El payback period de los controles es razonable?	Periodo de amortización de los controles de seguridad principales (meses)	M-ROI-04	Cuantitativa continua	Modelo financiero de seguridad
Q10.5: ¿La inversión en ciberseguridad está alineada con el ALE?	Ratio $inversión_{ciber} / ALE_{total}$ (inversión como % del riesgo cuantificado)	M-ROI-05	Cuantitativa ratio	Modelo ALE + presupuesto

4. Catálogo Unificado de Métricas GQM

Cód. Métrica	Denominación	OO	Componente COSO	IAT	Tipo de Medición
M-GOB-01	Frecuencia revisión ciberriesgo Consejo	OO-1	C-I	⚡	Cuantitativa discreta
M-GOB-02	% consejeros con competencia ciber acreditada	OO-1	C-I	⚡	Cuantitativa %
M-GOB-03	Nivel actividad Comité Ciber Consejo	OO-1	C-I	—	Ordinal 0-3
M-GOB-04	Independencia reporte CISO al Consejo	OO-1	C-I	⚡	Ordinal 1-5
M-GOB-05	Apetito de ciberriesgo cuantificado en euros	OO-1	C-II	⚡	Nominal + cuantitativa
M-EST-01	Nivel integración ciber en plan estratégico	OO-2	C-II	⚡	Ordinal 1-5
M-EST-02	Metodología de cuantificación de riesgo usada	OO-2	C-II	—	Nominal
M-EST-03	ALE total portafolio (euros/año)	OO-2	C-II	—	Cuantitativa continua
M-EST-04	Frecuencia actualización cuantificación del riesgo	OO-2	C-II	—	Cuantitativa discreta
M-EST-05	Ratio cobertura seguro / ALE	OO-2	C-II	—	Cuantitativa ratio
M-DET-01	MTTD — Mean Time to Detect (horas)	OO-3	C-III	⚡	Cuantitativa continua

M-DET-02	MTTR — Mean Time to Respond (horas)	OO-3	C-III	⚡	Cuantitativa continua
M-DET-03	Tendencia trimestral MTTD (delta %)	OO-3	C-III	—	Cuantitativa ratio
M-DET-04	% incidentes detectados internamente	OO-3	C-III	—	Cuantitativa %
M-DET-05	Dwell Time medio (días)	OO-3	C-III	—	Cuantitativa continua
M-VUL-01	Time-to-Patch crítico (CVSS $\geq$ 9.0) en días	OO-4	C-III	⚡	Cuantitativa continua
M-VUL-02	% CVE críticos sin parchear >30 días	OO-4	C-III	⚡	Cuantitativa %
M-VUL-03	% vulnerabilidad es priorizadas con EPSS	OO-4	C-III	—	Cuantitativa %
M-VUL-04	Cobertura VM en activos OT/IoT	OO-4	C-III	—	Cuantitativa %
M-VUL-05	% aplicaciones críticas con SBOM (<90 días)	OO-4	C-III	—	Cuantitativa %
M-IAM-01	% cuentas privilegiadas con MFA activo	OO-5	C-III	⚡	Cuantitativa %
M-IAM-02	% accesos remotos/cloud con MFA	OO-5	C-III	⚡	Cuantitativa %
M-IAM-03	Días desde última revisión cuentas privilegiadas	OO-5	C-III	—	Cuantitativa continua
M-IAM-04	Tiempo medio desprovisionin g en bajas (horas)	OO-5	C-III	—	Cuantitativa continua

M-IAM-05	% identidades no humanas inventariadas	OO-5	C-III	—	Cuantitativa %
M-SCM-01	% proveedores Tier-1 con evaluación <12 meses	OO-6	C-III	⚡	Cuantitativa %
M-SCM-02	% proveedores Tier-1 con monitorización continua	OO-6	C-III	—	Cuantitativa %
M-SCM-03	% contratos críticos con cláusulas de seguridad	OO-6	C-III	—	Cuantitativa %
M-SCM-04	% servicios críticos con BC ante fallo proveedor	OO-6	C-III	—	Cuantitativa %
M-SCM-05	% apps críticas terceros con SBOM monitorizado	OO-6	C-III	—	Cuantitativa %
M-RES-01	Ratio RTO real / RTO objetivo (%)	OO-7	C-III	⚡	Cuantitativa ratio
M-RES-02	Ratio RPO real / RPO objetivo (%)	OO-7	C-III	⚡	Cuantitativa ratio
M-RES-03	Número de pruebas DRP reales en 12 meses	OO-7	C-III	—	Cuantitativa discreta
M-RES-04	% ejercicios tabletop con participación C-level	OO-7	C-III	—	Cuantitativa %
M-RES-05	% backups críticos offline/inmutables verificados	OO-7	C-III	⚡	Cuantitativa %
M-EMG-01	% sistemas con inventario criptográfico completado	OO-8	C-II	⚡	Cuantitativa %

M-EMG-02	Estado hoja de ruta PQC (0-3)	00-8	C-II	—	Ordinal 0-3
M-EMG-03	% reglas SOC para ataques automatizados por IA	00-8	C-III	—	Cuantitativa %
M-EMG-04	% sistemas IA con evaluación riesgo pre-despliegue	00-8	C-III	—	Cuantitativa %
M-EMG-05	% datos vida útil >10 años evaluados SNDL	00-8	C-II	—	Cuantitativa %
M-RPT-01	Frecuencia reporte ciber al Consejo (veces/año)	00-9	C-V	⚡	Cuantitativa discreta
M-RPT-02	% indicadores en reporte expresados en términos financieros	00-9	C-V	—	Cuantitativa %
M-RPT-03	Calidad de comparativa estado/apetito en reporte (0-3)	00-9	C-V	—	Ordinal 0-3
M-RPT-04	Estado protocolo escalado incidentes (0-3)	00-9	C-V	⚡	Ordinal 0-3
M-RPT-05	Tiempo medio evento → conocimiento Consejo (horas)	00-9	C-V	—	Cuantitativa continua
M-ROI-01	ROSI del programa de ciberseguridad (%)	00-10	C-II	⚡	Cuantitativa continua
M-ROI-02	Gasto ciber / ingresos totales (%)	00-10	C-II	—	Cuantitativa ratio

M-ROI-03	Delta ALE: reducción de riesgo por programa (€/año)	OO-10	C-II	—	Cuantitativa continua
M-ROI-04	Payback period de controles principales (meses)	OO-10	C-II	—	Cuantitativa continua
M-ROI-05	Ratio inversión_cibe r / ALE_total (%)	OO-10	C-II	—	Cuantitativa ratio

5. Tabla de Niveles de Referencia (Benchmarks)

Métrica	Nivel Crítico	Nivel Aceptable	Nivel Óptimo	Fuente Benchmark
M-DET-01 MTTD	>7 días	1–7 días	<8 horas	IBM Cost of Data Breach 2025
M-DET-02 MTTR	>7 días	1–7 días	<4 horas	IBM Cost of Data Breach 2025
M-VUL-01 TTP crítico	>90 días	8–30 días	<7 días	ENISA NIS Investments 2025
M-IAM-01 MFA privilegiados	<80%	80–99%	100%	CIS Controls v8
M-GOB-01 Frecuencia Consejo	<1/año	Semestral	Trimestral o mayor	COSO CGF 2026 + Deloitte 2025
M-RES-01 Ratio RTO	>150%	110–150%	<105%	DORA Art. 11 + ISO 22301
M-ROI-02 Gasto/ingresos	<0.5%	0.5–1%	>1%	ENISA NIS Investments 2025

Marco GQM+PRAGMATIC — Kit GQM-PRAGMATIC v2025.1 | Abril 2026

Bases: Basili (1994) GQM · ISO/IEC 27004:2016 · ISO/IEC 15939:2007 · Brothby & Hinson PRAGMATIC (2013) · NIST SP 800-55 Rev.2 (2022) · COSO ERM 2017 · COSO CGF 2026 · FAIR · NIS2 · DORA · ENS